Rapport d’audit de sécurité Web

Template de rendu J4 - à dupliquer et compléter

Objectif :

Client	ACME Shop (OWASP Juice Shop)
Mission	Audit de sécurité Web - J4 autonomie
Période	10/09/2026
Auditeurs	Mohammed Ryad DERMOUCHE
Version	1.0
Classification	Pédagogique / Confidentiel lab

Consigne : privilégiez un rapport court et défendable. N’ajoutez pas un constat non confirmé pour augmenter artificiellement le nombre de vulnérabilités.

1. Résumé exécutif

Niveau global	☐ Bon ☐ Satisfaisant ☒ À renforcer ☐ Insuffisant
Justification en 3–5 lignes	L'audit a révélé que si certaines fonctionnalités bénéficient de contrôles efficaces (gestion des sessions, prévention des sauts d'étapes de paiement), l'application souffre de faiblesses critiques liées au manque de validation côté serveur. L'absence de requêtes préparées et de vérification d'appartenance des ressources expose la base de données et la vie privée des clients, tandis qu'un défaut de configuration expose des documents internes sensibles.
Risque principal	Compromission totale de la base de données (accès administrateur illégitime), vol massif des données de commandes clients (IDOR) et fuite de secrets d'infrastructure via des répertoires mal configurés.
Priorité immédiate	Corriger la faille d'injection SQL sur l'authentification (P1) et implémenter des contrôles stricts d'autorisation sur l'API des paniers (P1). Sécuriser immédiatement le répertoire d'archives FTP (P2).

1.1 Problématiques générales

Domaine	Niveau observé	Problématique générale	Priorité
Authentification / session	Faible	Absence de requêtes préparées permettant le contournement du login.	P1
Contrôle d'accès	Faible	Pas de vérification de l'appartenance des ressources (IDOR) côté API.	P1
Configuration / exposition	Faible	Listage de répertoires activé exposant des sauvegardes sensibles.	P2
API / logique métier	Moyen	Sécurisation séquentielle correcte (paiement) mais défaut de confidentialité (e-mails).	P4

1.2 Synthèse des constats

ID	Constat	Sévérité	CVSS	Priorité	Complexité
F-01	Contournement d'authentification via Injection SQL	Critique	9.3	P1	F
F-02	Accès non autorisé aux paniers clients (IDOR)	Élevée	7.1	P1	M
F-03	Exposition de répertoire sensible (Directory Listing) et fuite de documents	Élevée	7.1	P2	F

2. Contexte, périmètre et limites

2.1 Objectif de la mission

Le client ACME Shop souhaite obtenir une évaluation de sécurité de sa future plateforme e-commerce avant la mise en production, afin d'identifier les risques de fuites de données ou de compromission, et d'éprouver la robustesse de ses contrôles d'accès.

2.2 Périmètre

Cibles	Instance locale [http://127.0.0.1:3000] (Docker / OWASP Juice Shop).
Comptes / rôles fournis	Visiteur anonyme, comptes découverts dans les avis (admin@juice-sh.op, bender@juice-sh.op), et compte de test légitime (yawota5141@fidhost.com).
Mode	Black Box / Grey Box
Exclusions	Réseau de l'établissement, postes d'autres étudiants, services Internet tiers, attaques de déni de service (DoS) et actions destructrices
Tests interdits	DoS, destructif, hors scope, tiers non autorisés

2.3 Limites et réserves

Les tests ont été réalisés sur une durée limitée (timebox d'une journée avec prolongation). L'analyse s'est concentrée sur la surface applicative exposée (Grey Box / Black Box) sans accès au code source. Les vulnérabilités identifiées ont été exploitées uniquement jusqu'à la preuve de concept pour ne pas altérer la stabilité de l'environnement de laboratoire.

3. Méthodologie et couverture

Notre approche d'audit s'est déroulée de manière itérative et structurée, en respectant les contraintes de temps de la mission et le périmètre strict du laboratoire local. La méthodologie s'est articulée autour des phases suivantes :

- **Cadrage et Reconnaissance :** Définition des limites d'intervention (hébergement local exclusif), prise en main des comptes fournis (anonyme et compte de test) et observation passive du fonctionnement normal de l'application (ex: découverte d'identifiants potentiels dans les avis clients)

- **Cartographie et Énumération active:** Utilisation du proxy d'interception Burp Suite pour analyser le trafic légitime (requêtes et réponses HTTP), identifier la pile technologique et lister les endpoints sensibles de l'API. En complément, un fuzzing de découverte de contenus (Content Discovery) a été réalisé avec l'outil ffuf pour identifier des répertoires ou fichiers cachés non référencés par l'application (ex: découverte du répertoire /ftp)

- **Priorisation :** Sur la base du référentiel OWASP WSTG, nous avons ciblé les tests sur les vulnérabilités ayant le plus fort impact métier, en particulier les défauts d'authentification, d'autorisation (IDOR/BOLA) et de configuration

- **Tests Manuels et Validation :** Formulation d'hypothèses d'attaque (ex: "est-il possible de forcer l'accès à un autre compte ?") puis manipulation contrôlée et unitaire des paramètres HTTP via l'outil Repeater de Burp Suite pour observer le comportement du back-end.

- **Preuve et Restitution :** Confirmation des vulnérabilités par des preuves de concept (PoC) non destructives, capture des éléments démontrant l'impact et rédaction de fiches de constats axées sur la cause racine et la remédiation.

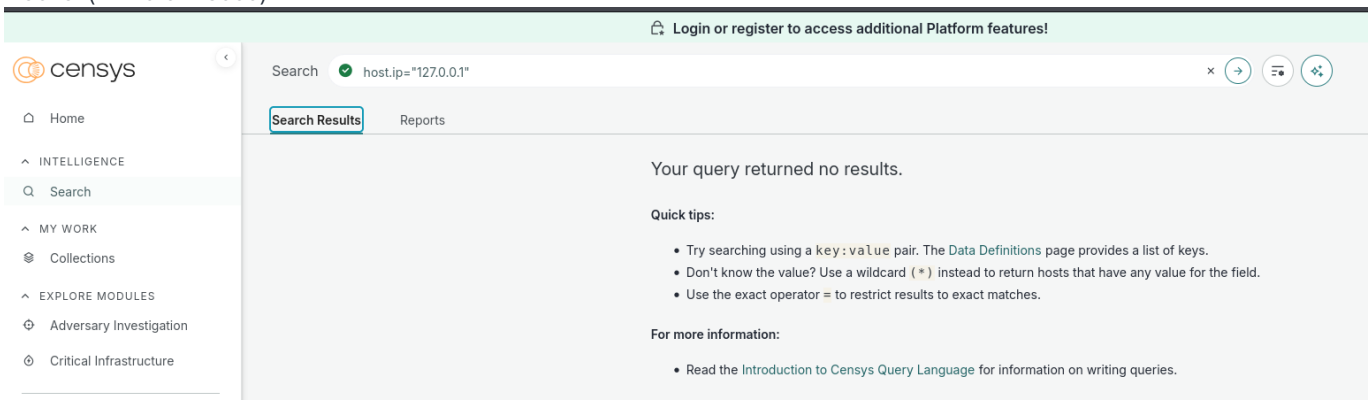
3.1 Surfaces testées

Surface / fonctionnalité	Testée ?	Résultat	Référence preuve / note
Reconnaissance / OSINT	Oui	Non concluant (Localhost)	3.2-A
Authentification	Oui	finding	F-01
Contrôle d'accès horizontal	Oui	finding	F-02-A / F-02-B
Contrôle d'accès vertical	Oui	RAS	Test négatif 3.2-B
Configuration / Découverte de contenu	Oui	finding	F-03-A / F-03-B
Logique métier (Paiement)	Oui	RAS	Test négatif contournement
Reconnaissance / Privacy	Oui	Point d'attention	Test négatif (Fuite d'e-mails) 3.2-C

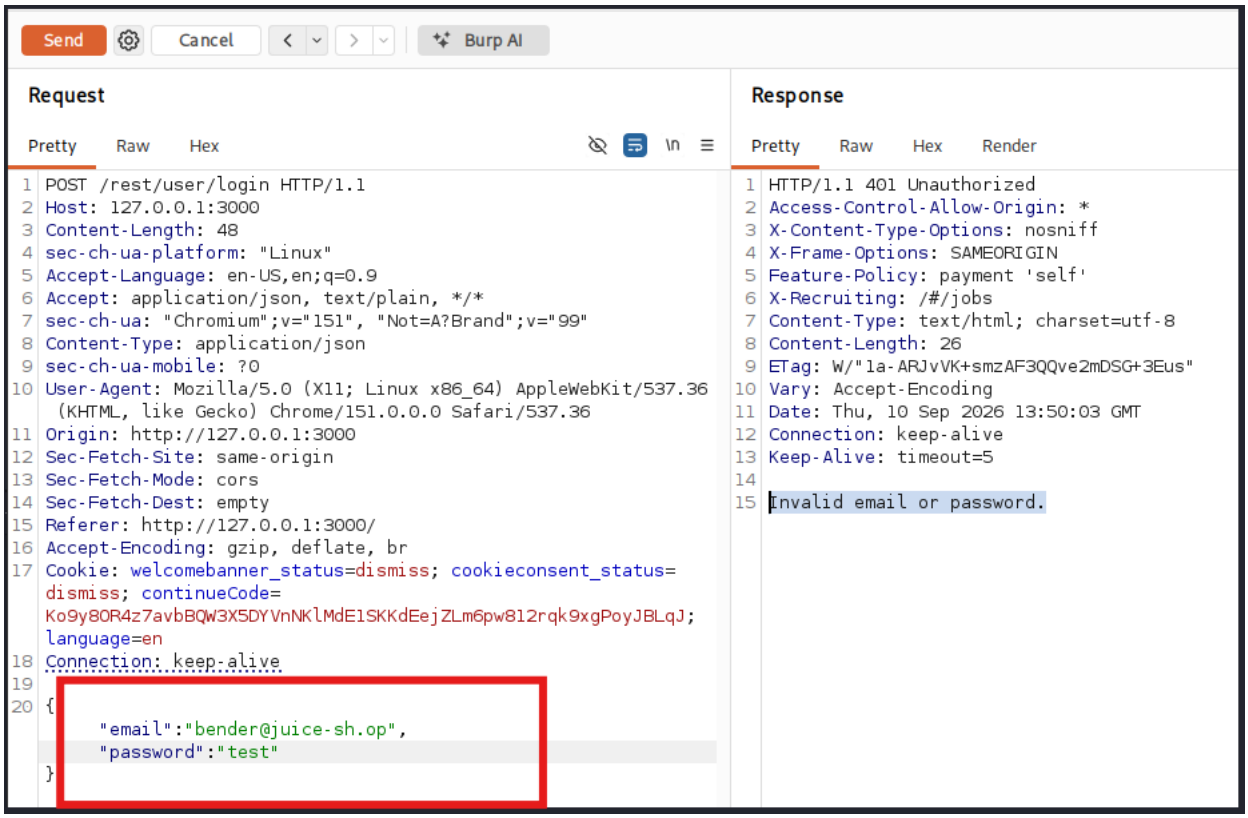
3.2 Tests négatifs et hypothèses infirmées

Lors de la phase de reconnaissance et d'énumération, plusieurs pistes ont été explorées afin de vérifier la robustesse des contrôles de sécurité. Les tests suivants n'ont pas révélé de vulnérabilités exploitables dans le cadre de cette mission, démontrant l'efficacité de certaines protections en place :

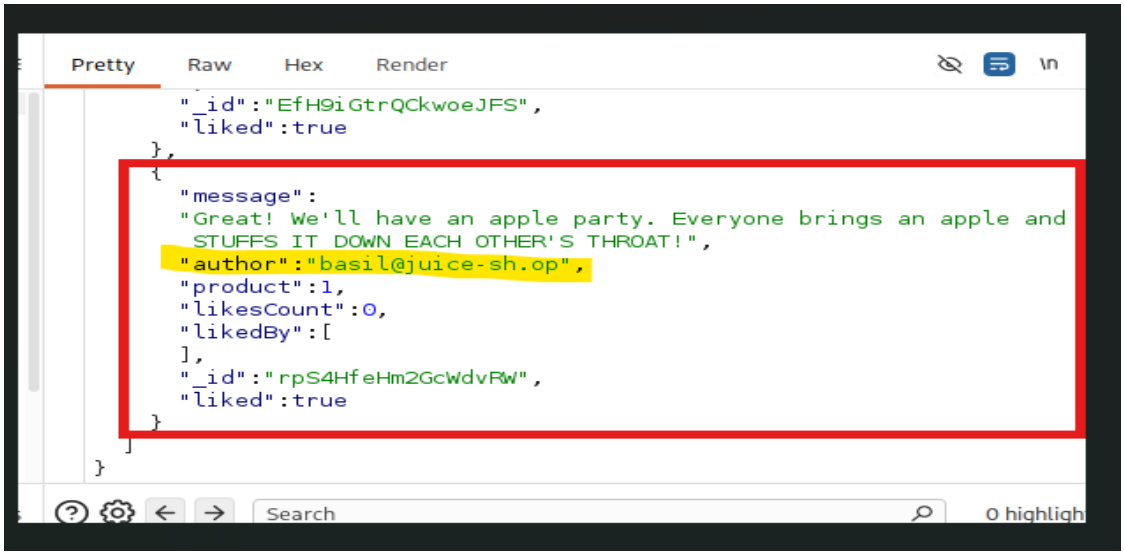
- **Reconnaissance passive (OSINT) :** L'utilisation de moteurs de recherche spécialisés (Shodan, Censys) s'est révélée impossible et hors-périmètre, l'application étant hébergée de manière confinée en local sur une instance Docker (127.0.0.1:3000)



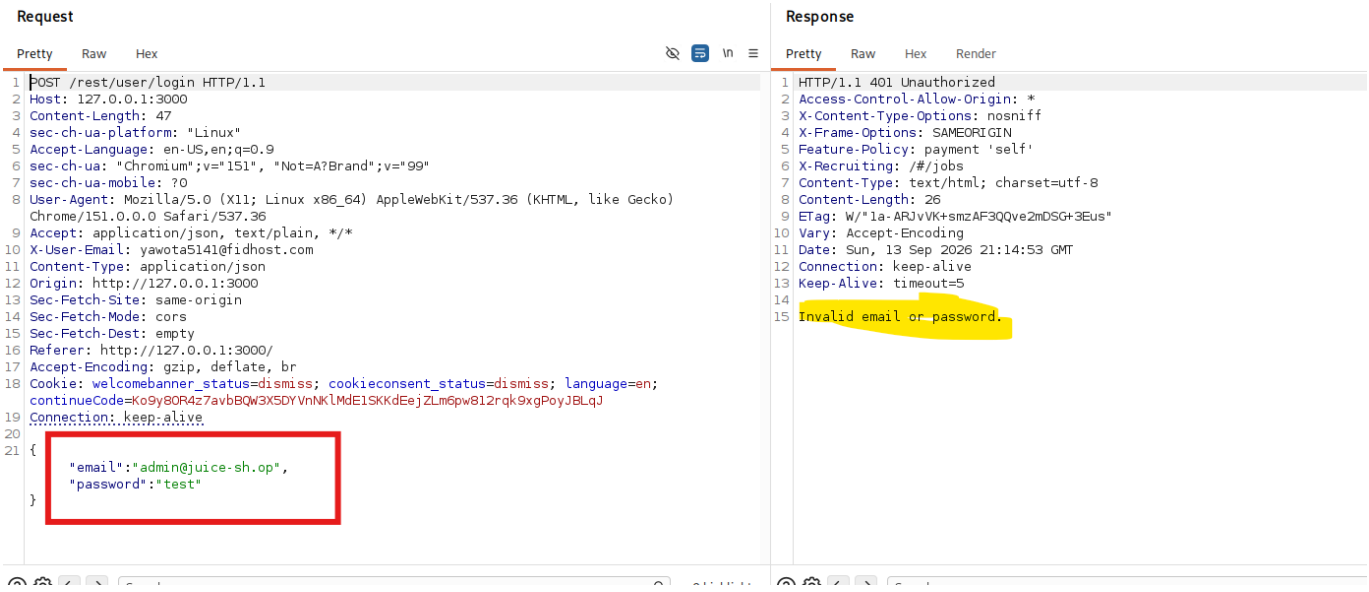
- **Énumération d'utilisateurs via le formulaire de Login :** Une tentative d'authentification ciblée sur le compte bender@juice-sh.op (découvert lors de la navigation) avec un mot de passe aléatoire a été correctement gérée par l'application. La réponse HTTP renvoie un message d'erreur générique (*Invalid email or password*). Ce comportement standard empêche un attaquant de confirmer l'existence d'un compte via des messages d'erreurs différentiels



- **Exposition d'informations (Privacy / Reconnaissance) :** L'observation légitime du site en tant que visiteur anonyme a permis de constater que la section des avis clients affiche publiquement les adresses e-mails complètes des auteurs (ex: admin@juice-sh.op). Bien qu'il s'agisse d'un défaut de conception limitant la confidentialité, ce point a été documenté comme une simple observation facilitant nos attaques ultérieures (phishing ou brute-force), et non comme une faille technique bloquante



- **Contrôle d'accès vertical (Élévation de privilèges) :** Une tentative d'accès direct à l'interface d'administration (/#/administration ou via l'API correspondante) en utilisant le jeton JWT de notre compte utilisateur standard (yawota5141@fidhost.com)) a été rejetée. Le serveur valide correctement le rôle administrateur pour cet accès spécifique, renvoyant un code HTTP 403 (Forbidden)



- **Logique métier (Saut d'étape de paiement) :** L'hypothèse de créer un nouveau compte (yawota5141@fidhost.com), d'ajouter des produits au panier et d'essayer de forcer la validation de la commande en sautant directement à l'URL de confirmation a été posée lors de la cartographie. Les contrôles séquentiels du back-end exigent bien qu'une étape de paiement soit validée pour finaliser le flux d'achat standard. *(Note : La manipulation avancée des paramètres de quantité en valeurs négatives via l'API pour annuler le montant n'a pas pu être approfondie dans le temps imparti).*

4. Constats détaillés

F-01 - Contournement d'authentification administrateur (Injection SQL)

Sévérité	Critique
CVSS	Version : 4.0| Score : 9.3 | Vecteur : CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
Priorité de remédiation	P1 immédiat
Complexité de remédiation	Faible: Implémentation de requêtes préparées standards
Actif / endpoint	/rest/user/login (POST)
Préconditions	Accès non authentifié (Anonyme)

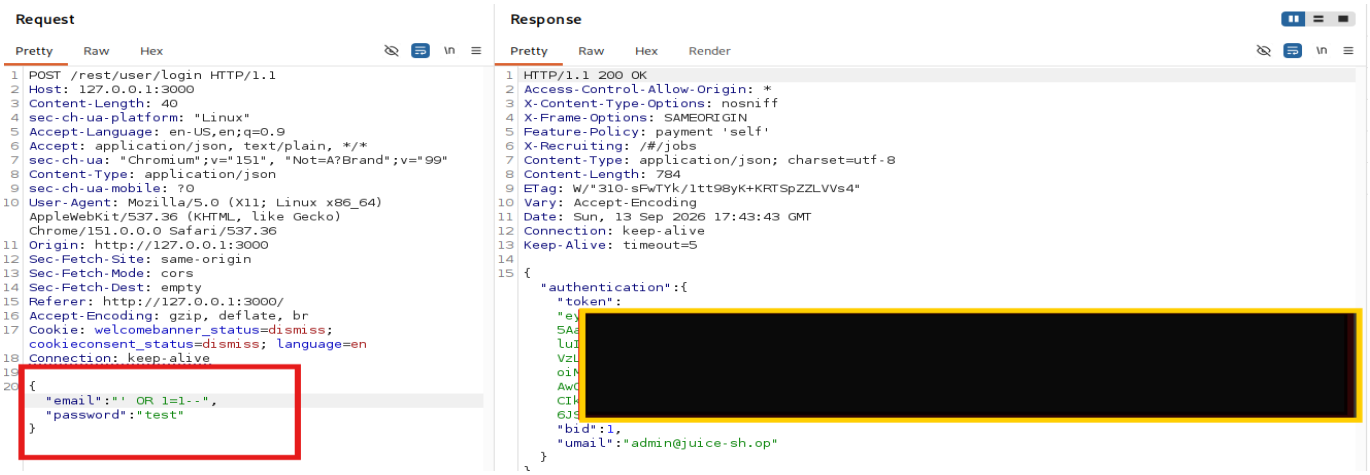
Description

L'API d'authentification ne valide pas les données envoyées dans le champ email avant de les insérer dans la requête SQL en base de données. Il est possible d'injecter du code SQL pour forcer l'authentification sur le compte administrateur, sans connaître son mot de passe.

Étapes de reproduction

1. Se rendre sur la page de connexion.
2. Intercepter la requête d'authentification (POST vers /rest/user/login) via Burp Suite.
3. Remplacer le contenu du champ "email" dans le corps JSON par : ' OR 1=1--
4. Laisser un mot de passe arbitraire et envoyer la requête.
5. Le serveur retourne un code 200 OK avec un jeton JWT valide pour admin@juice-sh.op.

Preuve



Impact

Technique: Prise de contrôle totale des droits applicatifs.

Métier: Un attaquant externe peut accéder à l'intégralité du back-office, consulter, modifier ou supprimer toutes les commandes et données personnelles des clients

Remédiation

Cesser de concaténer les variables directement dans les requêtes SQL. Utiliser systématiquement des requêtes préparées (Prepared Statements) ou un ORM (Object-Relational Mapping) correctement configuré, qui sépare la structure de la requête des données fournies par l'utilisateur.

Validation / re-test proposé

Soumettre la même charge utile "' OR 1=1-- "; l'application doit retourner un message générique d'échec d'authentification (HTTP 401 Unauthorized).

F-02 - Accès non autorisé aux paniers tiers (IDOR)

Sévérité	Élevée
CVSS	Version : 4.0 | Score : 7.1 | Vecteur : CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N
Priorité de remédiation	P1 immédiat
Complexité de remédiation	Moyenne: Nécessite la revue de la logique de contrôle d'accès sur l'ensemble de l'API REST
Actif / endpoint	/rest/basket/{id} (GET)
Préconditions	Compte utilisateur valide (ex: yawota5141@fidhost.com) via Temp Mail

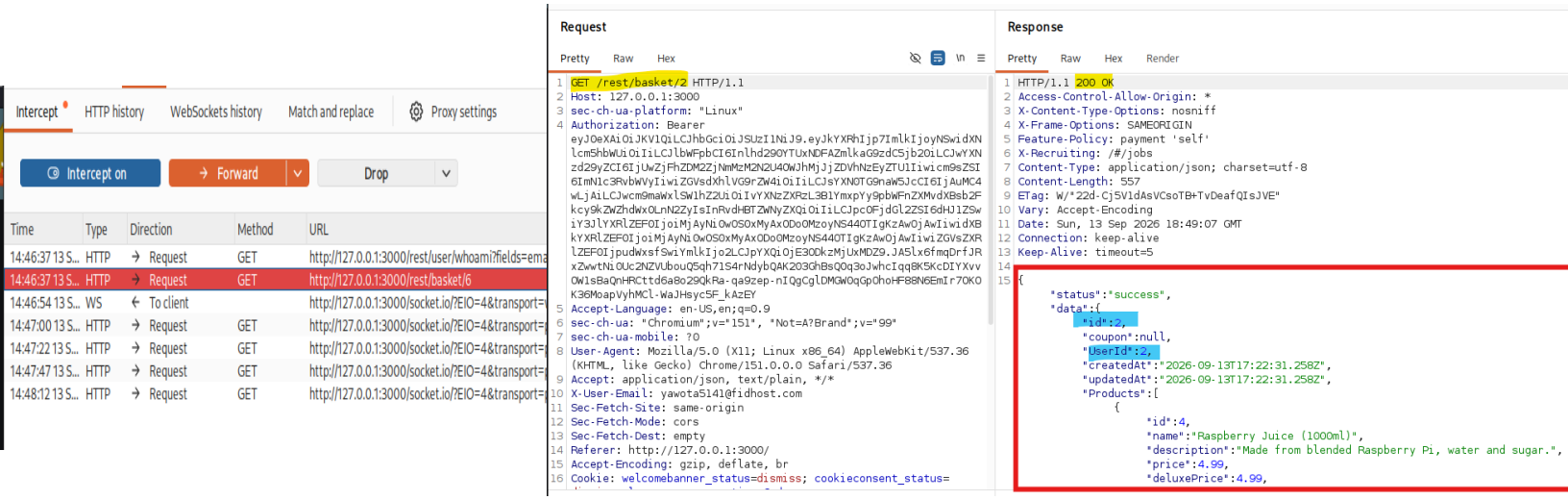
Description

Une vulnérabilité de type IDOR (Insecure Direct Object Reference) ou BOLA (Broken Object Level Authorization) est présente sur l'API de gestion des paniers. Le back-end vérifie que l'utilisateur est connecté (présence du JWT), mais ne vérifie pas si l'identifiant du panier demandé ({id}) appartient réellement à l'utilisateur effectuant la requête.

Étapes de reproduction

1- Se connecter avec le compte
2- de test (temp mail) et intercepter la consultation de son propre panier avec Burp
3- Envoyer la requête GET /rest/basket/6 vers le *Repeater* et modifier l'identifiant dans l'URL pour demander le panier 2 (GET /rest/basket/2).
4- L'API retourne le contenu complet du panier d'un autre client.

Preuve



Impact

Technique: Contournement du cloisonnement des données (Autorisation horizontale).

Métier: Violation de la confidentialité des clients. Un attaquant peut énumérer les identifiants (de 1 à 1000) et extraire les habitudes d'achats de toute la base client.

Remédiation

Ne plus faire confiance à l'identifiant de ressource fourni par le client. Côté serveur, extraire l'identité de l'utilisateur à partir de son jeton de session (JWT), et vérifier en base de données que le basketId demandé lui est bien rattaché avant de retourner les données.

Validation / re-test proposé

Avec le token de l'Utilisateur X , requêter "/rest/basket/2". Le serveur doit bloquer l'accès et retourner une erreur HTTP 403 (Forbidden) ou 401 (Unauthorized).

F-03 - Exposition de répertoire sensible (Directory Listing) et fuite de documents

Sévérité	Élevée
CVSS	Version : 4.0 | Score : 7.1 | Vecteur : CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
Priorité de remédiation	P2 court terme
Complexité de remédiation	Faible: un simple changement de configuration du serveur web pour désactiver le listage
Actif / endpoint	/ftp (GET)
Préconditions	Aucune / Anonyme

Description

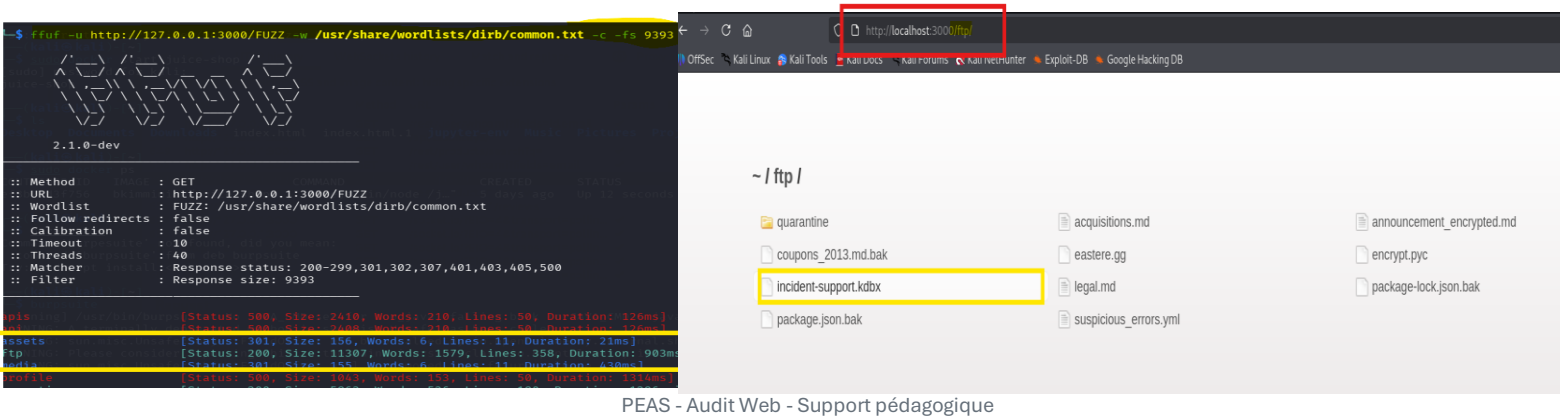
Le serveur web souffre d'un défaut de configuration (Security Misconfiguration) qui autorise le listage public du contenu des répertoires (Directory Listing). Le répertoire caché /ftp, découvert lors de la phase d'énumération, expose publiquement des fichiers de sauvegarde techniques (package.json.bak), des documents internes (acquisitions.md), et surtout un coffre-fort de mots de passe KeePass (incident-support.kdbx).

Étapes de reproduction

1- Lancer un outil de découverte de contenus (fuzzing) tel que ffuf sur la racine du serveur web.
2- Identifier le code de réponse HTTP 200 pour le chemin /ftp.
3- Naviguer manuellement vers l'URL [http://127.0.0.1:3000/ftp] depuis le navigateur.
4- Constater que le serveur liste les fichiers et permet leur téléchargement direct.

Preuve

L'interface affiche directement l'arborescence des fichiers sensibles :Preuve



Impact

Technique: Fuite d'informations critiques sur l'infrastructure (dépendances via package.json).

Métier: L'exposition du fichier .kdbx est critique : si un attaquant le télécharge et parvient à casser le mot de passe maître hors-ligne, il obtiendra les accès internes de l'équipe de support.

Remédiation

- Désactiver immédiatement la directive de listage des répertoires (Directory Listing) dans la configuration du serveur web.
- Déplacer ce répertoire de stockage hors de la racine web publique (webroot) pour empêcher tout accès direct via une URL.
- Restreindre l'accès à ces fichiers par un contrôle d'authentification et d'autorisation strict.

Validation / re-test proposé

Tenter d'accéder à nouveau à l'URL /ftp depuis un navigateur. Le serveur doit retourner une erreur HTTP 403 (Forbidden) ou 404 (Not Found), et ne plus lister les fichiers.

5. Plan de remédiation

Priorité	Action	Findings liés	Complexité	Résultat attendu
P1	Utiliser des requêtes préparées (Prepared Statements) ou un ORM strict pour l'authentification.	F-01	F	Les injections SQL sont neutralisées.
P1	Implémenter une vérification des permissions (Ownership check) côté serveur pour chaque ressource API demandée (ex: panier), basée sur le JWT.	F-02	M	Impossible d'accéder aux données d'un autre client (IDOR).
P2	Désactiver l'option de listage des répertoires (Directory Listing) dans le serveur Web et restreindre l'accès au dossier /ftp.	F-03	F	Les sauvegardes et fichiers internes (.kdbx) ne sont plus exposés.
P4	Masquer partiellement les adresses e-mails complètes dans la section des avis (amélioration "Privacy by Design").	N/A	F	Réduction du risque de phishing et d'énumération.

6. Conclusion

L'audit de la plateforme ACME Shop révèle un niveau de sécurité globalement insuffisant pour une mise en production en l'état. Si l'application a su démontrer une bonne résilience sur certains workflows métiers (blocage des sauts d'étapes de paiement) et sur l'élévation de privilèges directe, les lacunes fondamentales dans la validation des entrées (Injection SQL) et le contrôle d'accès sur les objets (IDOR) compromettent gravement l'intégrité de la base de données et la confidentialité des clients.

La correction des faiblesses P1 et P2 doit être entreprise immédiatement. Les remédiations proposées s'attaquent aux causes racines et sont, pour la plupart, de faible complexité technique. Un re-test est vivement recommandé à l'issue de l'application des correctifs.

7. Annexes

Outils utilisés :

- Navigateur Web (DevTools).
- Burp Suite Community Edition (Interception, Proxy, Repeater).
- ffuf (Fuzzing et Content Discovery).

Référentiel méthodologique : OWASP WSTG / OWASP Top 10 (A01: Broken Access Control, A03: Injection, A05: Security Misconfiguration).

Note de révision : Conformément aux clauses de confidentialité internes de l'entreprise, ce document a bénéficié d'une révision orthographique et syntaxique assistée par Intelligence Artificielle (IA) hébergée en circuit fermé. Aucune donnée technique ou contextuelle liée au rapport n'a été divulguée ou utilisée pour l'entraînement de modèles tiers. (scénario imaginé)

Checklist avant remise

- Chaque finding a un titre compréhensible et un actif concerné.
- Les preuves sont lisibles et ne contiennent pas de secrets inutiles.
- Les étapes de reproduction sont complètes.
- Le CVSS comporte sa version et, si possible, son vecteur.
- La remédiation traite la cause racine.
- La complexité de remédiation est justifiée indépendamment de la sévérité.
- Le résumé exécutif présente les problématiques générales et les priorités.
- Les limitations et zones non couvertes sont mentionnées.
- Le rapport a été relu par un autre membre du groupe.